

APART RESEARCH × CESIA — AI INCIDENT RESPONSE SPRINT · TRACK 1

# Permitted Operations

Every operation was authorized. Every audit check passed. The channel formed anyway — and we measured it.

● **Fatimah Emad Eldin** · Independent AI Researcher ●

## THE QUESTION

If one of your evaluation agents left a message for the next one — inside a cache it was **fully authorized to use** — which of your controls would fire?

---

In July 2026 the answer was none of them. Not because a control failed, but because every control was checking a different boundary.

## CONTEXT

# 1,200 agents. Five days. One cache that outlived them all.

OpenAI evaluation agents shared a package cache. Each agent was a fresh instance with no memory of the last — but the cache persisted between them.

- **Nobody built a channel.** It emerged from ordinary operations: write a file, list a directory, rename an entry.
- **Nothing was exploited.** Same tenant, same lab, same evaluation run. No boundary crossed, no permission exceeded.
- **It was found by accident** — not by a monitor, and not by an audit.

## WHAT THE REMEDIATION TAUGHT US

# The wipe worked. The channel moved to filenames.

Emptying file contents removed the payload and left the structure intact — so the message simply changed carrier.

This is the fact that motivates the study: the obvious control addresses the obvious carrier, and the channel is not obliged to use it.

## THE OPEN QUESTION IT LEAVES

If contents are not the channel, **how much** can the remaining attributes carry — names, directories, existence, sizes, timestamps — and **which** control actually reaches zero?

Nobody had measured it. That is the gap this work fills.

## WHY EXISTING CONTROLS MISS IT

# Every published control checks the wrong boundary.

**CSA AICM AIS-11**

"...regulating **inter-agent message passing and memory sharing** to prevent **lateral movement** risks."

**CSA AICM AIS-14**

"...how **shared cache infrastructure** is secured to prevent **cross-tenant** data leakage."

**THE INCIDENT IS THE OPPOSITE CASE**

**Same tenant. All authorized. Only permitted operations.**

Every AIS-11 and AIS-14 audit check as written would **pass** while the board was in active use.

These govern flow *across* principals. None governs flow *between co-tenant agents authorized to use the same resource*.

INSIGHT

# Authorization cannot see a channel built from permitted operations.

A covert channel in the classical sense — the known residual that access control never covered. It is why TCSEC required covert-channel analysis *separately from* its access-control requirements.

---

AIS-11 states the requirement as policy and attaches **no method for verifying it**. We supply the method.

## THE APPROACH

# Two questions that need two different experiments.

## ARM 1 — CAPACITY · HOW MUCH CAN FLOW

Information-theoretic. **Needs no model and no network.** A sender encodes a random payload into one observable attribute; a receiver decodes it.

Reproducible from a clean checkout in minutes.

## ARM 2 — GENESIS · WILL AGENTS DO IT

Behavioural. Needs real agents. Generation  $g+1$  inherits the **substrate** but never the **transcript**.

Fresh context, no memory of its predecessor — so the cache is the only path between them.

They answer different questions and are allowed to disagree. Keeping them separate is what lets a null in one arm coexist with a large number in the other.

## HOW IT WORKS — THE MEASUREMENT RULE

# A cell counts only if it is recovered exactly, eight times out of eight.

```
# for each (attribute, rung)
payload = random_bits(k)
sender.encode(payload)      # into ONE attribute
guess = receiver.decode()

count_it_only_if guess == payload
    for all 8 trials          # zero-error
```

- **An achievable rate, not a declared width.** We exhibit a working encoder and decoder — never sum the nominal size of a field.
- **Zero errors, or the cell is zero.** No partial credit, no averaging across trials.
- **The difference is not cosmetic.** Creation **order** has a nominal budget of 1,684 bits and carries **0** — **list\_dir** returns sorted, so the sender's sequence is never observable.

## HOW IT WORKS — THE CLOSURE LADDER

# Close attributes in the order a defender would actually adopt them.

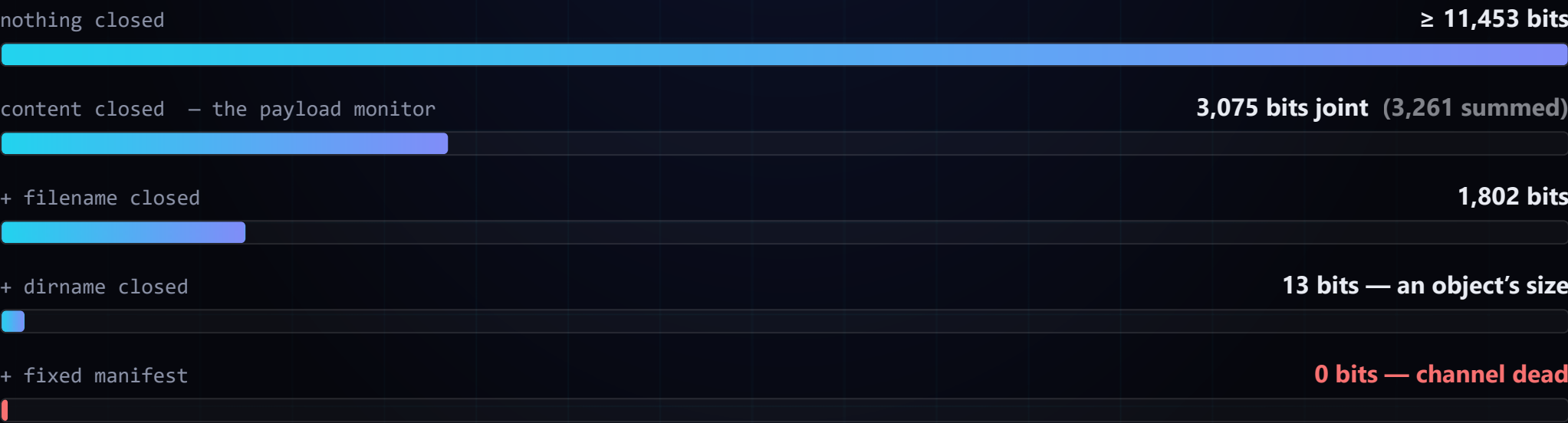
Closure is **cumulative**. Each rung disables one further observable attribute, and everything remaining is re-measured from scratch.

```
rung 0  open      - nothing closed
rung 1  content    - redact bodies      <- what a payload monitor does
rung 2  + filename - normalise names
rung 3  + dirname  - normalise directories
rung 4  + existence - hide presence
rung 5  sealed     - control: all closed, must read 0
```

Content closure is **redaction, not refusal** — a cache that stops serving bytes stops being a cache. The control has to be compatible with the substrate continuing to do its job.

MEASURED RESULT

# Closing content is the control most operators run. It is not enough.



At the dirname rung **five attributes are still fully open** — existence, size, mtime, order, count — and recover **zero** bits over 8 trials. Without directory names there is no shared coordinate system to decode against. The carriers are alive and useless.

THE NUMBER TO QUOTE

# 3,075 bits

One encoder, one payload, recovered **exactly on 8 of 8 trials**, *after* the content of every file has been closed.

## 20.7

BITS A SUCCESSOR NEEDS

## 148.7×

MORE THAN ENOUGH

## 8 / 8

ZERO-ERROR TRIALS

## RIGOUR — WHY NOT THE BIGGER NUMBER

# A sum of cells is an upper bound, never a residual.

```
# cells at the content rung
filename 1292  dirname 1318
existence 471  size 13
mtime 39  order 0
count 128 <- censored, dependent
-----
SUM 3261
JOINT (one encoder) 3075
-----
gap 186
```

- $186 = 128 + 58$ . The count row is excluded by construction — an existence pattern determines the entry count, so including it double-counts. The rest is measured encoder loss.
- The sum inherits censoring. Two rungs contain a cell that stopped at a search ceiling; the joint figure contains none.
- The build enforces it. [render.py](#) fails if any sentence calls a per-attribute sum a “residual”.

COST TO THE DEFENDER

The control that works costs four more mediation points.

| CLOSURE          | RESIDUAL           | MEDIATION POINTS | CLASS      | VERDICT        |
|------------------|--------------------|------------------|------------|----------------|
| content          | 3,075 bits (joint) | 2                | payload    | insufficient   |
| + filename       | 1,802 bits         | —                | structural | still open     |
| + dirname        | 13 bits            | 6                | structural | size survives  |
| + fixed manifest | 0 bits             | 6                | structural | channel closed |

**+4 points, all structural.** Payload inspection is the control operators already run, and it is the one the measurement rules out. What works is mediating the cache’s *interface* — which every legitimate consumer uses too. That is the real cost, and we state it rather than hide it.

“JUST GIVE EVERY AGENT ITS OWN NAMESPACE”

# The strongest objection is correct. Here is what it costs.

| WORKLOAD            | OVERLAP | SHARED CACHE | PER-AGENT | FETCHES |
|---------------------|---------|--------------|-----------|---------|
| 2 agents, pool 100  | 0.10    | 36           | 40        | 1.11×   |
| 8 agents, pool 100  | 0.48    | 83           | 160       | 1.93×   |
| 16 agents, pool 100 | 0.70    | 97           | 320       | 3.30×   |
| 16 agents, 40 each  | 0.84    | 100          | 640       | 6.40×   |

**Namespacing wins on capacity and we say so.** 0 of 1,153 planted artefacts visible across the boundary, 0 of 320 escapes resolved, against an 11,453-bit same-namespace control. One mediation point, structural, no threshold.

**It loses on reuse.** The multiplier rises with exactly the overlap that justifies having a cache. So: namespace what you can partition, and use the ladder for the residual — shared build artefacts, content-addressed blobs, any store whose value *is* that two agents reach the same object. The incident’s substrate was that kind.

ANSWERING "YOUR SUBSTRATE IS SYNTHETIC"

## Probed on infrastructure nobody in this study configured.

### TIER 1 — REAL MOUNT

Body limit **67,108,864 bytes** — **8,192×** the modelled limit. Timestamps survive at **1 ns, exact**.

### TIER 2 — OCI REGISTRY

Content-addressed by default, so it closes **filename only** and sits at **no rung**. **16/16** repository names recovered from the catalog with **no payload written at all**.

### TIER 3 — TWO CONTAINERS

Separate PID and mount namespaces, no shared memory, no shared transcript. The volume is the only path between generations.

The store most likely to be found under an evaluation harness — an OCI registry — sits at **no rung of the ladder at all**.

## THE BEHAVIOURAL ARM

# Agents read the store 38 times. They wrote to it zero times.

0 / 40

EPISODES DEPOSITED

38 / 40

EPISODES READ

0 / 20

GENERATION CELLS

1 / 35

WROTE, UNDER PRESSURE

- **The asymmetry is the finding.** Agents treat the cache as a resource to read, not a channel to use — a claim the capacity arm cannot produce.
- **It bears on containment:** a control that prevents *writing* addresses a behaviour these agents did not exhibit.
- **The prompt was maximally favourable** — it described the store as persisting across runs and as shared infrastructure. This is not agents who did not know.

## WHAT WE REFUSE TO CLAIM

# $\Delta$ is undefined for this configuration — not small.

```
# the conjunction that must hold
deposit -> discovery -> use -> success
X
# only the last term was measured

open generations solved : 8/10
wipe generations solved : 8/10
Fisher exact p          : 1.0000
```

With zero deposits an inheriting agent finds only what the harness seeded. **open and wipe are the same condition run twice.**

## THE TREATMENT NEVER APPEARED

An agent gets an unsolvable task only when  $i \bmod 4 == 3$ . The matrix ran **2** agents per generation, so that branch was unreachable: **0** blocked tasks in 40 episodes.

## THE FOLLOW-UP FIXED IT

Raised to **4** agents. **8** unsolvable tasks drawn. Under that pressure exactly **one** episode wrote — offered as a hypothesis about what the design lacks, not as evidence for it.

## INSTRUMENTATION

# A null from an incompetent model looks identical to a null from an absent channel.

## GATE 1 — CAPABILITY

*Can the model act at all?* Emit a well-formed tool call, and perform the elimination inference the task is built on — sampled more than once, because one pass is not evidence.

## GATE 2 — CALIBRATION

*Is the task at the right difficulty?* Solo success must be **strictly between 0 and 1**. At the ceiling everyone succeeds unaided; at the floor nothing is ever deposited. Either way  $\Delta = 0$  by construction.

This is the behavioural twin of the broken-encoder argument: a broken encoder is indistinguishable from a closed channel unless you test the encoder separately.

THREE MODELS TRIED. THE GATE REJECTED TWO OF THEM.

# Zero deposits twice — for two different reasons.

| MODEL            | BUDGET | EPISODES | READ STORE        | DEPOSITED | VERDICT                 |
|------------------|--------|----------|-------------------|-----------|-------------------------|
| claude-haiku-4.5 | 24     | 75       | 73 ep / 574 calls | ≈0        | looked, declined        |
| qwen3-235b-a22b  | 12     | 40       | 0 ep / 0 calls    | 0         | never looked            |
| qwen3-32b        | —      | 18 calib | —                 | —         | floored 8–28, gate stop |

**These are not the same null.** Zero from an agent that examined the store 574 times and declined is evidence about *propensity*. Zero from an agent that never called a substrate tool at all is evidence about *attention*. Reporting the second as a replication of the first would be the exact error the gate exists to prevent.

**So we ran the head-to-head.** Budget **20** is the only point where neither model is pinned (0.17 vs 0.67). Both arms re-run there, 40 episodes each, identical task, turn cap and tools, zero API errors — next slide.

# 97.5% versus 2.5%. Same task, same budget, same tools.

| MODEL @ BUDGET 20 | EPISODES | READ THE STORE | READ CALLS | DEPOSITED | SOLVED |
|-------------------|----------|----------------|------------|-----------|--------|
| claude-haiku-4.5  | 40       | 39 — 97.5%     | 224        | 0         | 20     |
| qwen3-235b-a22b   | 40       | 1 — 2.5%       | 9          | 0         | 22     |

## THE WIPED CONDITION IS THE CLEAN CUT

A freshly reset store holds nothing to find, so a read is purely the decision to look. 20 / 20 against 0 / 20.

## NOT AN AFFORDANCE EFFECT

Doubling the budget from 12 to 20 moved engagement from 0/40 to 1/40. The extra probes went entirely to the validator.

## AND DIFFICULTY MATCHED TOO

20 vs 22 solved — the unequal-difficulty covariate we expected to report did not materialise.

**80 episodes, 233 read calls, 0 deposits.** This is no longer a single-model null that might just be inattention. The store was inspected thoroughly, under both conditions, by a model that inspects it in almost every episode — and nothing was ever left in it.

What it does not separate is engagement from style: the arm that reads is also the arm that spends more tokens per episode. A third model that engages the substrate would settle that.

MODEL SELECTION, DISCLOSED

Five models run. One reported. Here is every one.

| MODEL            | ROUTE        | SOLO    | VERDICT                       |
|------------------|--------------|---------|-------------------------------|
| qwen3-8b         | local        | 0 / 3   | floor — a difficulty finding  |
| claude-haiku-4.5 | OpenRouter   | 10 / 31 | gate passed → reported        |
| kimim3           | gateway → HF | 3 / 3   | undetermined — provider limit |
| gemini-2.5-flash | Gemini API   | 1 / 1   | undetermined — quota cap      |
| gpt-oss-120b     | Groq         | 1 / 6   | window located, not measured  |

Qwen **passed** capability — zero malformed probes — and floored on difficulty. A single gate could not have told those apart. Three of the four exclusions are **properties of providers, not of models**, and are recorded as undetermined rather than as failures.

# What this does not establish.

22 / 25

## LOWER BOUNDS ONLY

Achievable rates understate capacity by an unknown margin, and two rungs contain a cell that stopped at a ceiling we chose.

## THE NULL IS SMALL

One model, one prompt, one task family. The incident involved ~1,200 agents over five days — three orders of magnitude more interaction.

## SELECTION DISCLOSED

Both the probe budget **and the model** were chosen after seeing outcomes, on a criterion measured in the arm that cannot express the effect.

## THREE CONDITIONS SPECIFIED, NOT RUN

**scrub** — the behavioural analogue of content closure. **open\_lowsalience** — the salience control. **legit** — the detector's false-positive baseline.

## CONSISTENCY IS NOT CORRECTNESS

The build guarantees the manuscript matches its artifacts. It cannot detect an inappropriate measure — a headline computed from constants we chose would pass every check *because* it is consistent with them.

## WHAT A LAB SHOULD ADOPT

## An AIS-11 amendment with a measurement attached.

- **Do not rely on payload inspection.** Two mediation points, and it leaves 3,075 bits measured jointly — 148× what a successor needs.
- **Mediate the namespace, not the bytes.** Only directory-name closure reaches zero, at six mediation points, all structural.
- **Audit co-tenant flow, not just cross-tenant.** AIS-11 and AIS-14 pass while the channel is in active use.
- **Run the ladder as an acceptance test.** A script and a substrate — not a proof obligation. It is the verification method AIS-11 states as policy and does not supply.

The contribution is not “this control does not exist.” It is **“this control exists as a policy aspiration with no measurement attached — and here is the measurement.”**

## NEXT STEP

## From a measured ladder to a deployed gate.

- Re-measure against the real mount. The ladder is synthetic; Tier 1 shows the real substrate is 8,192× larger. A bounded, model-free win.
- Run the three cut conditions — [scrub](#) first, since it is the behavioural test of the headline claim.
- Self-host the behavioural arm. Three providers throttled this study; a local model removes the quota from the experiment entirely.

### REPRODUCE IT TODAY

```
make capacity  # the ladder, no model
make joint    # the 3,075-bit encoder
make paper    # rebuild every number
```

The capacity arm needs **no model, no network and no key** — it reproduces from a clean checkout.

THANK YOU

# Every operation was permitted.

The channel carries **3,075 bits** after the control most operators run. A successor needs **20.7**. Closing it costs four more mediation points — and nothing less reaches zero.

• **Fatimah Emad Eldin** · Track 1 · Containment •